# Règles d'accès

Nous décrivons ici les règles d'accès qui viennent compléter les règles métier du backend.

> ⚠ **Précédence des règles métier sur les règles d'accès**
>
> **Les règles métier doivent être respectées en priorité par rapport aux règles d'accès.** Autrement dit :
>
> - Les règles d'accès définissent *qui* peut théoriquement effectuer une action sur une entité (exemple : lire, modifier, supprimer une occurrence).
> - Les règles métier définissent *dans quelles conditions* une action peut être réalisée, en fonction de la logique métier propre à l'application et indépendamment de qui effectue l'opération.
>
> Même si une règle d'accès autorise un utilisateur à exécuter une opération, cette dernière doit être bloquée si elle viole une règle métier.
>
> **Exemple concret :**
>
> Un manager peut, selon les règles d'accès, modifier le statut d'une réservation pour ses restaurants.
>
> Cependant, les règles métier imposent des restrictions supplémentaires : il ne pourra pas modifier le statut d'une réservation terminée ou annulée, ni effectuer des transitions de statut non autorisées (par exemple, passer de `completed` à `pending` ou de `cancelled` à `confirmed`).

## Visiteur

Un visiteur est un utilisateur non authentifié.

| Règles d'accès par concept métier | READ | CREATE | UPDATE | DELETE |
|---|---|---|---|---|
| User | indirectement au login (vérification email/mot de passe) et au signup | au signup | non | non |

| **Règles d'accès par concept métier** | **READ** | **CREATE** | **UPDATE** | **DELETE** |
|---|---|---|---|---|
| | (vérification unicité email et nom) | | | |
| Restaurant | non | non | non | non |
| Service | non | non | non | non |
| Table | non | non | non | non |
| Reservation | non | non | non | non |
| Tables d'une réservation | non | non | N/A | non |
| Managers d'un restaurant | non | non | N/A | non |
| Date simulée | oui | non | oui | non |

## Client

| **Règles d'accès par concept métier** | **READ** | **CREATE** | **UPDATE** | **DELETE** |
|---|---|---|---|---|
| User | ses données | non | non | non |
| Restaurant | oui | non | non | non |
| Service | oui | non | non | non |
| Table | indirectement pour vérifier les | non | non | non |

| Règles d'accès par concept métier | READ | CREATE | UPDATE | DELETE |
|---|---|---|---|---|
| | disponibilités | | | |
| Reservation | les siennes + indirectement celles des autres pour vérifier les disponibilités | pour lui-même | les siennes | non |
| Tables d'une réservation | indirectement pour vérifier les disponibilités | non | N/A | indirectement quand modifie une de ses réservations confirmée |
| Managers d'un restaurant | non | non | N/A | non |
| Date simulée | oui | non | oui | non |

## Manager

| Règles d'accès par concept métier | READ | CREATE | UPDATE | DELETE |
|---|---|---|---|---|
| User | ses données et celles des clients qui ont réservé pour ses restaurants | non | non | non |
| Restaurant | pour ses restaurants | non | non | non |

| **Règles d'accès par concept métier** | **READ** | **CREATE** | **UPDATE** | **DELETE** |
|---|---|---|---|---|
| Service | pour ses restaurants | pour ses restaurants | pour ses restaurants | pour ses restaurants |
| Table | pour ses restaurants | pour ses restaurants | pour ses restaurants | non |
| Reservation | pour ses restaurants | non | le statut, pour ses restaurants | non |
| Tables d'une réservation | pour ses restaurants | pour ses restaurants | N/A | pour ses restaurants |
| Managers d'un restaurant | non | non | N/A | non |
| Date simulée | oui | non | oui | non |

## Admin

Le rôle d'administrateur n'est pas implémenté. Il est cependant couvert automatiquement par le fait que l'utilisateur `postgres` a tous les droits d'accès sur les tables de la base de données.

Cependant, une fois la base de données créée et les règles métier mises en place, même l'utilisateur `postgres` doit s'y soumettre.

Prenons un exemple pour illustrer cela : l'administrateur peut supprimer une table d'un restaurant, ce que ne peut pas faire un manager. Cependant, une telle suppression implique de supprimer par cascade les assignations de cette table à des réservations, ce qui ne doit être autorisé que si la règle métier sur la capacité totale des tables associées à ces réservations n'est pas violée.

Vous devez aussi vérifier que votre implémentation des règles métier ne perturbe pas les droits d'accès de l'administrateur. Par exemple, l'administrateur doit pouvoir supprimer un restaurant ou un user.